UNIVERSITÄT PASSAU
Fakultät für Informatik und Mathematik

5820 UE Exercises: Advanced IT-Security



Prof. Dr. Joachim Posegga
Emiliia Gelóczi

Task 1

UNIVERSITÄT PASSAU
Fakultät für Informatik und Mathematik

Match each term (1–8) to the most appropriate definition (A–H).



1. Asset
2. Threat
3. Vulnerability
4. Safeguard
5. Risk
6. Residual risk
7. Protection requirement
8. Value

A. A weakness that may allow a harmful event to occur.
B. A measure that reduces threats or vulnerabilities.
C. Something worth protecting.
D. A potential source of harm to an asset.
E. An indication of the importance of an asset.
F. A need for protection arising from identified risk.
G. The possibility and consequences of harm, depending on assets, threats, vulnerabilities and safeguards.
H. Risk that remains after safeguards are applied.

Task 1

UNIVERSITÄT PASSAU
Fakultät für Informatik und Mathematik

Give concrete examples for each term.

1. Asset
2. Threat
3. Vulnerability
4. Safeguard
5. Risk
6. Residual risk
7. Protection requirement
8. Value

Task 1 – Example Solution

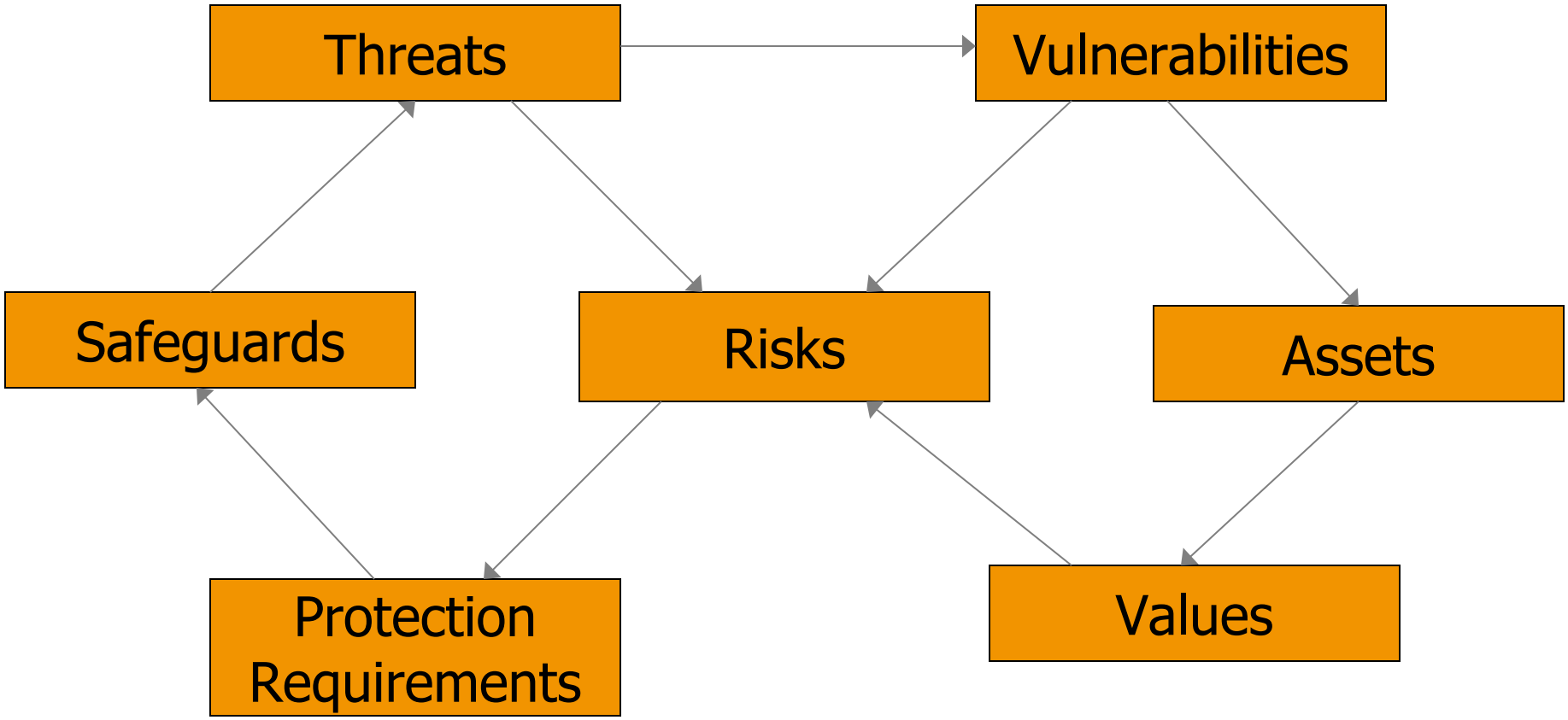
Give concrete examples for each term.

1.	Asset	Examination database and student records
2.	Threat	Unauthorised grade modification or disclosure
3.	Vulnerability	Weak password, excessive permissions, missing updates
4.	Safeguard	Role-based access control, MFA, backups, monitoring
5.	Risk	Exam data may be changed/exposed if weaknesses are exploited
6.	Residual risk	Account compromise may still occur despite MFA and monitoring
7.	Protection requirement	Only authorised examiners should be able to alter grades
8.	Value	Correct grades, student privacy, service trust and reputation

Task 1

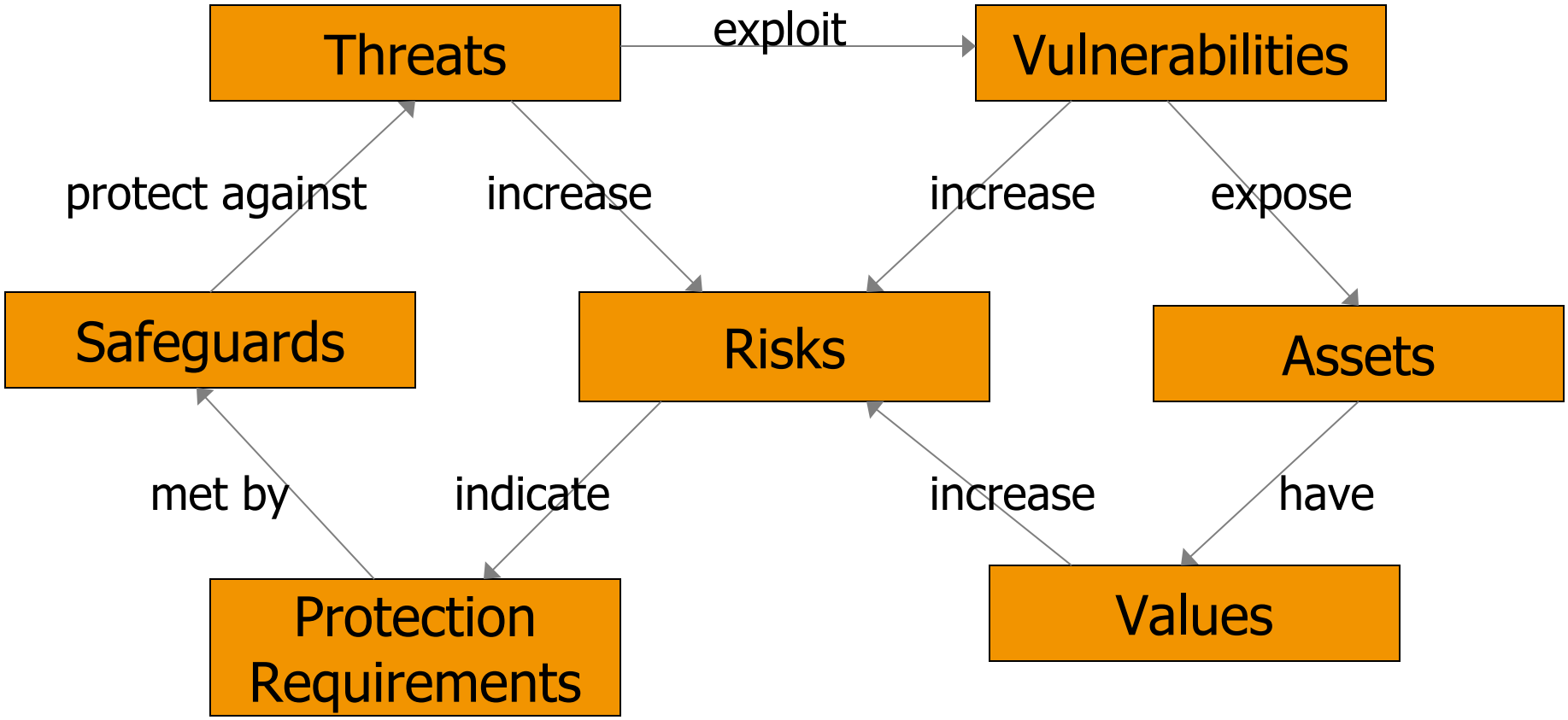
Put the terms in relation.

exploit - increase - protect against - have - expose - are met by - indicate



Task 1

Put the terms in relation.



Task 1

UNIVERSITÄT PASSAU
Fakultät für Informatik und Mathematik

Which three elements of security are presented in the lecture?
Explain these elements in your own words!

Policy

Mechanism

Assurance

Task 1 - Solution

Which three elements of security are presented in the lecture?
Explain these elements in your own words!

Policy:	*Specifying* security What is it supposed to do?
Mechanism:	*Implementing* security How does it do it?
Assurance:	*Correctness* of security Does it really work?

Task 2

a) Why are attackers classified as indicated in the lecture?

b) Give an example for each of these classes!

Class I: “Clever Outsiders”. Intelligent, has technical knowledge and simple equipment. Tend to use known vulnerabilities of systems

Class II: “Knowledgeable Insiders”. Technical Training/Education, in-depth knowledge of systems, has access to sophisticated equipment

Class III: “Funded Organizations”. Teams of specialists, access to relevant (Insider-) Information, access to dedicated euquipment and significant resources (time, money, personnel)

Task 2 - Solution

UNIVERSITÄT PASSAU
Fakultät für Informatik und Mathematik

a) Why are attackers classified as indicated in the lecture?

Attacker classifications help us make explicit assumptions about access, behaviour, resources, capabilities and incentives. These influence the threat model and the selection of safeguards.

b) Give an example for each of these classes!

Insider: employee abusing access to view grades.
Outsider: unknown Internet user attacking a login page.
Passive: eavesdropper only listening to unencrypted traffic.
Active: intruder modifying records or sending malicious requests.
Financially motivated: ransomware criminal.
Espionage motivated: adversary secretly collecting research data.

An attacker can belong to multiple categories.

A university operates an online examination system. Consider the following potential adversaries:

Profile A — External observer
Can monitor traffic on a public Wi-Fi network, but has no authorised account.

Profile B — Student account holder
Has a valid student account and can submit examination registrations, but is not authorised to change grades.

Profile C — System administrator
Has privileged access to the system and its database, but must follow university policy.

Task 2

a) Rank these profiles by their potential access privileges. Why does access alone not determine how dangerous an attacker is?

C (administrator) >

B (student) >

A (external observer)

Profile A — External observer
Can monitor traffic on a public Wi-Fi network, but has no authorised account.

Profile B — Student account holder
Has a valid student account and can submit examination registrations, but is not authorised to change grades.

Profile C — System administrator
Has privileged access to the system and its database, but must follow university policy.

b) For each profile, describe one plausible misuse of its capabilities and the security goal primarily threatened.

c) Select a safeguard for each misuse and explain one important limitation (residual risk) of that safeguard

Profile	Plausible misuse / CIA	Safeguard	Residual risk
A: External observer			
B: Student			
C: Administrator			

Task 2

UNIVERSITÄT PASSAU
Fakultät für Informatik und Mathematik

Profile	Plausible misuse / CIA	Safeguard	Residual risk
A: External observer	Read unencrypted traffic / confidentiality	Authenticated encrypted connections	Compromised endpoints or metadata leakage
B: Student	Submit another student's registration or exploit flawed authorisation / integrity	Server-side authorisation checks	Logic errors or stolen credentials
C: Administrator	Illegitimately edit examination records / integrity	Least privilege, separation of duties, audited actions	Privileged misuse, collusion, logging failure

d) Explain why the same defence cannot address all three profiles equally well.

Task 3

UNIVERSITÄT PASSAU
Fakultät für Informatik und Mathematik

An IoT temperature sensor in a university laboratory is defective and reports 43 .C when the actual temperature is 23 .C. The device digitally signs its measurements. The signed value reaches the server without alteration, and the signature verifies successfully.

(a) Has the **signed message** been modified in transit? What does successful signature verification tell the server in this scenario?

(b) Does the reported temperature necessarily describe the real world correctly? Distinguish **data integrity** from the accuracy of the **measurement**.

(c) Identify an asset, a vulnerability or fault, a possible risk, and one safeguard.

Task 3 - Solution

UNIVERSITÄT PASSAU
Fakultät für Informatik und Mathematik

An IoT temperature sensor in a university laboratory is defective and reports 43 .C when the actual temperature is 23 .C. The device digitally signs its measurements. The signed value reaches the server without alteration, and the signature verifies successfully.

(a) Has the **signed message** been modified in transit? What does successful signature verification tell the server in this scenario?

No alteration in transit is described. Successful signature verification indicates that the signed data was not modified after signing and was produced using the corresponding signing key, under the assumed security of the signature scheme and key.

(b) Does the reported temperature necessarily describe the real world correctly? Distinguish **data integrity** from the accuracy of the **measurement**.

The temperature is still wrong: 43 °C was signed but the actual temperature is 23 °C. Cryptographic integrity of a message does not establish the real-world correctness of a sensor measurement.

(c) Identify an asset, a vulnerability or fault, a possible risk, and one safeguard.

Asset: laboratory temperature information or the process relying on it.
Vulnerability: defective sensor.
Risk: incorrect safety alarms or incorrect automatic control. Safeguard: independent reference sensor, calibration or plausibility checks.

Task 3

A university states: "Only authorised examiners may modify students' grades." It enforces this with access controls. Before deploying the system, administrators test that student accounts cannot modify grades.

(a) Identify the **policy**, **mechanism** and **assurance** activity described above.

(b) Why is a security mechanism alone not sufficient to claim that a system is secure?

Task 3 - Solution

UNIVERSITÄT PASSAU
Fakultät für Informatik und Mathematik

A university states: "Only authorised examiners may modify students' grades." It enforces this with access controls. Before deploying the system, administrators test that student accounts cannot modify grades.

(a) Identify the **policy**, **mechanism** and **assurance** activity described above.

Policy: only authorised examiners may change grades.
Mechanism: access controls.
Assurance activity: testing student accounts to confirm changes are denied.

(b) Why is a security mechanism alone not sufficient to claim that a system is secure?

A mechanism can be incorrectly configured, implemented with defects or fail under unexpected conditions; its behaviour must be assessed against the policy.

Task

UNIVERSITÄT PASSAU
Fakultät für Informatik und Mathematik

For each situation, identify the primary security property affected (Confidentiality, Integrity, or Availability) and explain your choice in one sentence. More than one property may be relevant; focus on the primary one.

(a) Someone reads students' private exam records without permission.

(b) An attacker changes a student's grade in the university database.

(c) A university web service becomes unreachable during course registration.

(d) A file is accidentally altered during transmission.

(e) A confidential report is made publicly downloadable.

Task - Solution

UNIVERSITÄT PASSAU
Fakultät für Informatik und Mathematik

For each situation, identify the primary security property affected (Confidentiality, Integrity, or Availability) and explain your choice in one sentence. More than one property may be relevant; focus on the primary one.

Situation	Primary property	Reason
(a) Private exam records read without permission	Confidentiality	Unauthorised disclosure
(b) Student grade modified	Integrity	Unauthorised alteration
(c) Registration service unreachable	Availability	Legitimate users cannot use the service
(d) File accidentally altered in transit	Integrity	Data changed unexpectedly
(e) Confidential report publicly downloadable	Confidentiality	Unauthorised access is possible

For each scenario, identify the attacker's likely position, behaviour, and a plausible motivation. Indicate the main securitygoal(s) threatened (confidentiality, integrity, availability). Briefly justify ambiguous answers

(a) A university employee downloads examination records to sell them to a third party.

(b) A visitor captures unencrypted wireless traffic to read other users' messages, without transmitting malicious packets.

(c) A criminal encrypts files on a company's server and demands payment for their recovery.

(d) An administrator deliberately changes a colleague's access permissions to prevent them from working.

(e) A researcher, without permission, tests a university login portal by repeatedly attempting guessed passwords.

Task - Solution

UNIVERSITÄT PASSAU
Fakultät für Informatik und Mathematik

For each scenario, identify the attacker's likely position, behaviour, and a plausible motivation. Indicate the main securitygoal(s) threatened (confidentiality, integrity, availability). Briefly justify ambiguous answers

Scenario	Position	Behaviour	Motivation	CIA
S1	Insider	Active	Financial gain	C
S2	Outsider	Passive	Information collection	C
S3	Unspecified / often outsider	Active	Extortion	A, I
S4	Insider	Active	Disruption / retaliation	A, I
S5	Outsider (no authorised account stated)	Active	Curiosity / research	Potential C, A

Notes: S3 may also affect confidentiality if data is stolen; S5 has an active attempt even if no password is guessed. S4 changes authorisation data (integrity) and denies work access (availability). An attacker may be both an insider and active, and one incident can threaten multiple CIA properties.

Task

Find the ten security terms below. Words can go in any direction and share letters as they cross over each other.

T I C B W T W E Y U L A A Y N
Q A T K S V F Y T E Y Z V H U
O Z E I G C T T I X V W A P A
A V N R N D F W L Z B O I A E
J O O V H T I G I K D T L R L
H T I V B T E P B R C K A G T
V E J Z E A O G A A N V B O X
A S J T T L C U R K Y Z I T T
R I S K I G G O E I Y Q L P B
E D Q C D E Y H N Y T R I Y L
O N Y K F N K W L H G Y T R T
D N U A M I S S U V I I Y C I
V L S R K L X I V O L U R W E
E C N A R U S S A M O U A I A
C Z G H F T E S S A F H D R L

Task

UNIVERSITÄT PASSAU
Fakultät für Informatik und Mathematik

Find the ten security terms below. Words can go in any direction and share letters as they cross over each other.

